SEFU HMIS — Data Protection, Privacy & Patient Consent Policy

Kenya Digital Health Agency (DHA) & Office of the Data Protection Commissioner (ODPC) Compliance

Statutory Basis: Kenya Data Protection Act 2019, Kenya Digital Health Act 2023, Kenya Health Act 2017

System Classification: Health Information System (HIS) & Electronic Medical Record (EMR)

Applicability: Hospital Staff, Clinical Practitioners, Patients, and Software Vendor

---

■ 1. Policy Overview & Governance

Attribute	Specification
Document Title	Comprehensive Data Protection, Privacy Notice & Patient Consent Policy
System Name	SEFU Hospital Management Information System (SEFU HMIS)
Version	1.0 (Statutory Filing Standard)
Approved by	Data Protection Officer (DPO) & Medical Superintendent
Target Audience	Hospital Clinical Officers, Administrative Staff, Patients, Regulators
Effective Date	November 2026

■ 2. Hospital Privacy Notice & Patient Data Collection

2.1 Our Commitment to Patient Privacy

SEFU HMIS and its partner healthcare facilities are committed to protecting the privacy, confidentiality, and dignity of every patient. When patients access healthcare services, the hospital collects and processes medical and personal information strictly to provide safe, accurate, and high-quality clinical care.

2.2 What Information We Collect:

- **Identification & Demographics:** Name, date of birth, age, gender, National ID / Alien ID, physical address, and contact numbers.
- **Medical & Clinical Data:** Symptoms, vital signs, physical examination findings, medical histories, diagnoses, and treatment plans.
- **Specialty Health Information:** Antenatal and obstetric details, pediatric growth milestones, and physiotherapy session evaluations.
- **Diagnostic Records:** Laboratory sample parameters, blood test results, radiology images, and pathology reports.
- **Medication Records:** Prescribed pharmaceuticals, dosage intervals, and dispensing logs.
- **Billing & Financials:** Treatment costs, payment receipts (Cash/M-Pesa), and Social Health Authority (SHA) / private insurance coverage details.

■ 3. Patient Consent Management Procedure

In accordance with Section 32 of the Kenya Data Protection Act 2019 and the Kenya Health Act 2017, patient consent must be informed, explicit, and freely given.

3.1 Standard Clinical Consent Protocol

1. **Intake Notice:** At the front desk during patient intake, registration clerks present the **Patient Privacy and Consent Notice** in English or Kiswahili.
2. **Scope of Consent:** Patients (or their legal guardians in the case of minors) confirm consent for:
   - Creation of an electronic health record in SEFU HMIS.
   - Access to their medical record by attending physicians, nurses, pharmacists, and diagnostic technicians involved in their care team.
   - Submission of required clinical and financial claims to their authorized health insurer (SHA or private TPA).
   - Receipt of appointment reminders and laboratory result notifications via SMS or email.
3. **Electronic & Physical Documentation:** Consent is acknowledged physically on the patient intake form and recorded as a boolean flag in the patient's electronic file.

3.2 Emergency & Incapacitated Patients

In trauma or life-threatening emergency situations where a patient is unconscious, incapacitated, or unaccompanied:

- Clinical treatment and electronic health record creation proceed immediately under the **Vital Interests Exception** (Section 30(1)(b) of the Kenya Data Protection Act 2019 and Section 14 of the Kenya Health Act 2017).
- Formal consent is documented retrospectively once the patient regains capacity or when an authorized next of kin arrives.

3.3 Withdrawal of Consent

- Patients hold the statutory right to withdraw consent for non-clinical processing (such as automated SMS health tips or optional research).
- Withdrawal of consent cannot be applied retroactively to eliminate medical records required by statutory healthcare retention laws.

■ 4. Data Subject Rights Fulfillment Procedure

The hospital provides transparent channels for patients to exercise their statutory rights under Part IV of the Kenya Data Protection Act 2019:

4.1 Right of Access (Section 26)

- Patients can view their visits, prescriptions, and billing receipts via the **Patient Portal** (`/site/userlogin`).
- Patients or their authorized legal representatives may submit a formal Data Access Request to the Hospital Medical Records Department. Certified copies of clinical summaries are provided within **7 business days**.

4.2 Right to Rectification (Section 28)

- If a patient identifies an inaccuracy in their demographic data (e.g. misspelled name, updated telephone, change of address), they can request an update at the registration desk.
- Clinical entries (e.g., historical doctor notes or lab results) cannot be erased; necessary clinical corrections are entered as signed addendums, with the historical entry preserved in the audit trail.

4.3 Right to Erasure / De-Identification (Section 40)

- Requests for complete erasure of clinical health records are subject to statutory medical retention mandates. Where the retention window has expired, records are systematically de-identified or purged under medical board supervision.

■ 5. Data Retention, Archival & Secure Disposal Policy

To comply with the Kenya Medical Practitioners and Dentists Council (KMPDC) and public health laws:

Record Classification	Statutory Retention Period	Storage Protocol	Final Disposal Protocol

Adult Outpatient & Inpatient Records	**7 Years** from last visit	Active / Online MariaDB Database	Cryptographic zero-fill overwrite & audit log archiving
Pediatric Records	Until patient reaches **25 Years**	Active Database & Cold Storage	Supervised medical board disposal sign-off
Maternity & Obstetric Records	**25 Years**	Cold Archive Storage	Secure cryptographic sanitization
System Security & Audit Trails	**7 Years**	Immutable `logs` & `userlog` tables	Archived to write-once (WORM) media

■ 6. Cross-Border Data Transfer Safeguards

In accordance with Section 48 and Section 49 of the Kenya Data Protection Act 2019:

1. **Kenya Data Localization:** All primary production databases, diagnostic scans, and daily backups of SEFU HMIS are hosted exclusively within the sovereign territory of the Republic of Kenya or in designated Tier-3 cloud data center regions possessing equivalent data protection legislation.
2. **Cross-Border Transfer Restrictions:** Sensitive patient health information is strictly prohibited from being transferred, replicated, or stored outside Kenya without:
   - Explicit verification of adequate data protection laws in the recipient jurisdiction.
   - Written authorization from the Office of the Data Protection Commissioner (ODPC).
   - Legitimate necessity for cross-border medical evacuation or specialized referral.

■ 7. Data Processing Agreement (DPA) Framework

Between the **Healthcare Facility (Data Controller)** and **SEFU Health Systems Limited (Data Processor)**:

- **Processor Warranties:** The software provider warrants that it processes patient data strictly upon documented instructions from the hospital, enforces confidentiality among all personnel, and implements state-of-the-art technical security controls (MFA, RBAC, Bcrypt, DRP).
- **Sub-processor Restrictions:** No third-party sub-processors may access patient health data without prior written authorization from the hospital.
- **Incident Cooperation:** In the event of a security incident, the processor must notify the controller within **24 hours** to enable statutory 72-hour reporting to the ODPC.

Approved by:

Data Protection Officer & Medical Superintendent

SEFU Health Systems — Kenya Digital Health Agency (DHA) Compliance